SOC Level 1: Unified SIEM Project

By:

1. Taher Al-Omari

2. Zaid Alnatour

3. Mohammad Zaiedan

4. Omar Qasim

5. Basel Abunaemeh

Supervisor**:**

Eng.Ahmad Alawneh

Table of Contents

List of Figures 3

Phase 1 – SIEM Deployment 4

Phase 2 – Log Integration 5

2.1 Linux Log Integration 5

2.2 Windows Log Integration 5

2.3 Validation & Event Visibility 5

Phase 3 – Use Case Development 7

3.1 Detection Logic Definition 7

3.2 Rule Creation 7

3.3 Severity & MITRE Mapping 7

3.4 Validation & Testing 7

3.5 Advanced Correlation Strategy & Detection Depth 9

Phase 4 – Event Generation 10

4.1 True Positive Event 10

4.2 False Positive Event 12

4.3 Explanation & Comparison 13

Phase 5 – Investigation & Handling 14

5.1 Identify and Open the Triggered Alert 14

5.2 Timeline Analysis of Alert Activity 15

5.3 Detailed Event Field Analysis 16

5.4 Contextual Log Correlation and Behavior Validation 17

5.5 Impact Assessment and Severity Determination 18

5.6 Extended Analytical Pivots 19

Phase 6 – Escalation Ticket 19

6.1 Incident Summary 20

6.2 Detection Source 20

6.3 Timeline of Events 20

6.4 Impact Assessment 21

6.5 Evidence 21

Log Evidence: 21

Rule Trigger Evidence: 21

Screenshot References: 21
6.6 Severity Justification 22
6.7 Recommendation / Next Steps 22
Phase 7 – Rule Tuning & Improvement 23
7.1 Reducing False Positives 23
Threshold Adjustment 23
Time Window Adjustment 23
Host Exclusion Strategy 23
7.2 Production-Level Enhancements 23
Correlation with SSH Authentication Events 23
Tiered Alert Escalation Logic 24
User Behavior Baseline Monitoring 24

List of Figures

Figure 1 – Operational Wazuh Dashboard After Successful Deployment 4
Figure 2– Active Linux and Windows Agents Registered in Wazuh 5
Figure 3– Linux Authentication Events Successfully Ingested 6
Figure 4– Windows Security Events Successfully Ingested 6
Figure 5– Custom Rule 100020 XML Configuration 8
Figure 6– Custom Rule 100020 Loaded and Active in Wazuh 8
Figure 7– True Positive Alert Trigger 10
Figure 8– Expanded Raw Event Details (True Positive) 11
Figure 9– False Positive Alert Trigger 12
Figure 10– Identification of Triggered Alert (Rule ID 100020) 14
Figure 11– Filtered Timeline of True Positive Incident 15
Figure 12– Event Context Fields 16
Figure 13– Rule & Detection Metadata 17
Figure 14– Correlated Authentication Failure Events 18

Phase 1 – SIEM Deployment

Wazuh Community Edition was deployed on a dedicated Linux virtual machine to serve as the central SIEM platform for this project. Prior to installation, system time synchronization and network configuration were verified to prevent service or certificate issues.

The official Wazuh all-in-one installer was used to deploy:

- Wazuh Manager
- Wazuh Indexer
- Wazuh Dashboard

Installation completed successfully without errors.

After deployment, the dashboard was accessed via web browser, administrator authentication was confirmed, and all core services were verified as running. The dashboard displayed active agents communicating successfully with the manager, confirming stable SIEM operation.

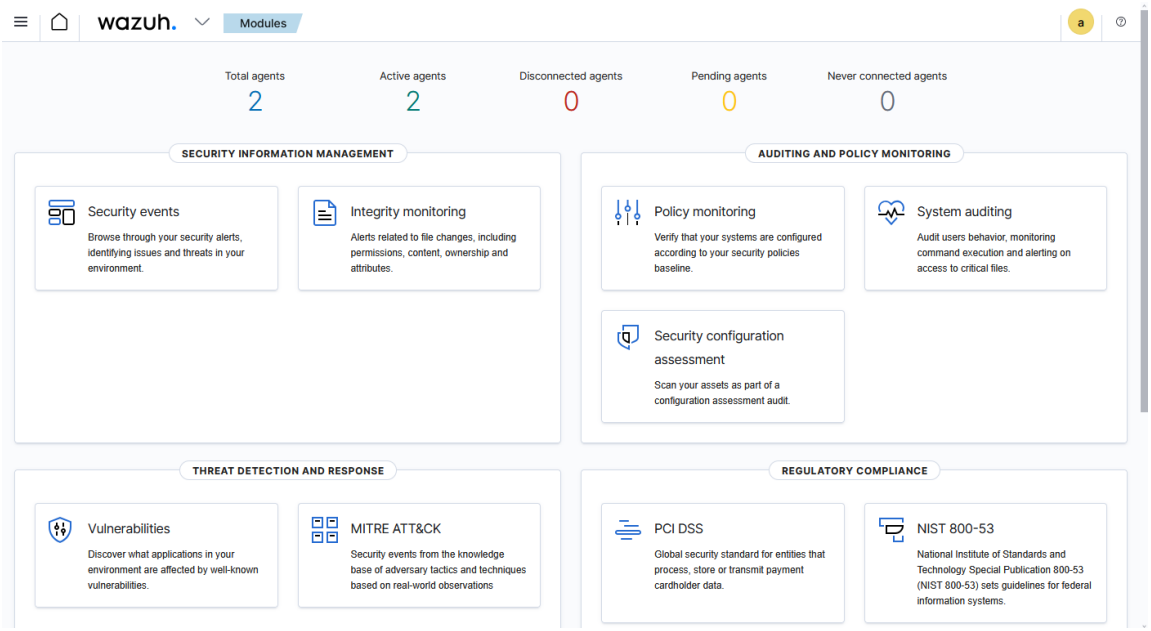

Figure 1 – Operational Wazuh Dashboard After Successful Deployment

Phase 2 – Log Integration

2.1 Linux Log Integration

The Wazuh agent was installed on the Kali Linux host and configured to communicate with the manager. The agent registered successfully and appeared as **Active** in the dashboard. Linux authentication logs (SSH and sudo) were successfully ingested and visible in the Security Events view.

2.2 Windows Log Integration

The Wazuh Windows agent (v4.7.5-1) was installed and registered using the manager IP and authentication key. The Windows host appeared as **Active**, confirming stable communication. Windows Security Event Logs were successfully indexed and displayed in the dashboard.

2.3 Validation & Event Visibility

Both Linux and Windows agents were confirmed active, and security events from both systems were visible in the SIEM. This validates successful log integration from both sources.

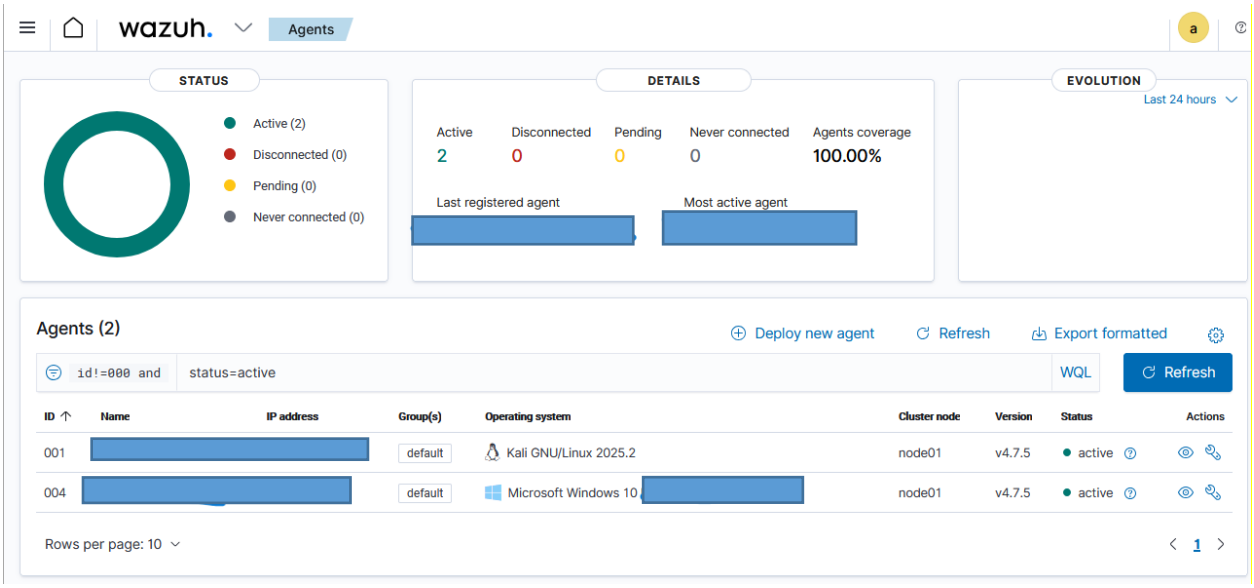

Figure 2– Active Linux and Windows Agents Registered in Wazuh

Both Kali Linux and Windows endpoints are successfully registered and communicating with the Wazuh manager.

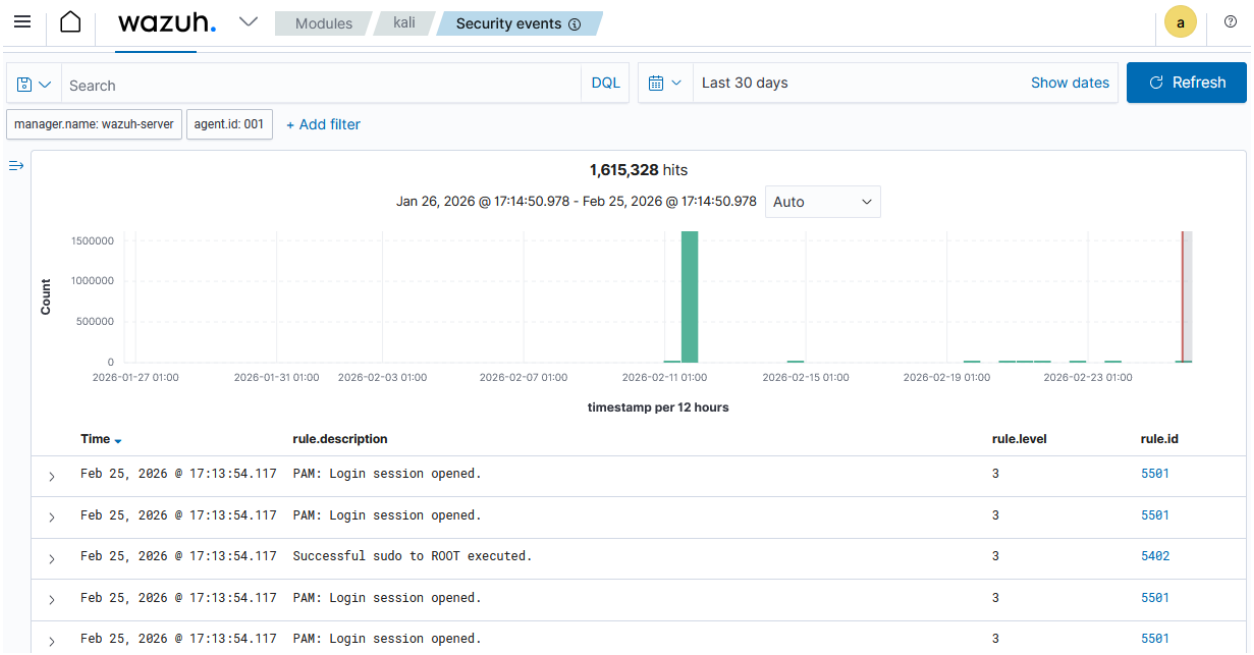

Figure 3– Linux Authentication Events Successfully Ingested

Security events from the Kali Linux host are visible in the Wazuh dashboard, confirming successful Linux log integration.

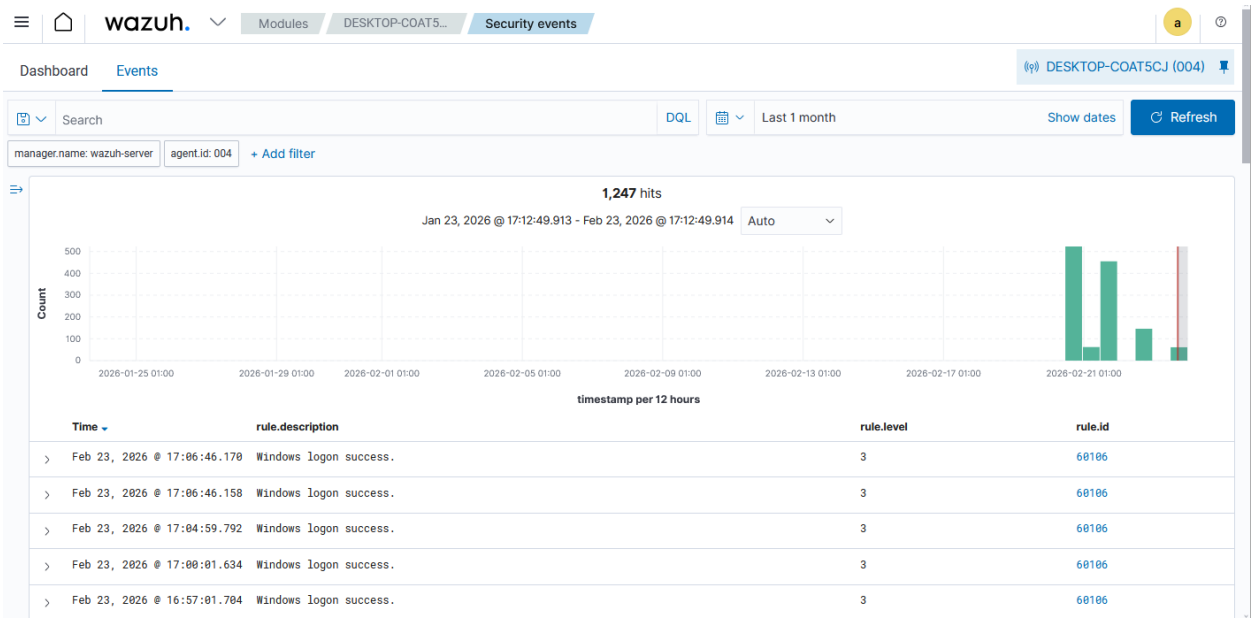

Figure 4– Windows Security Events Successfully Ingested

Windows Security Event Logs are indexed and visible in the Wazuh dashboard, confirming successful Windows log integration.

Phase 3 – Use Case Development

3.1 Detection Logic Definition

This use case detects repeated failed sudo authentication attempts on a Linux system to identify potential privilege escalation activity. The logic correlates multiple occurrences of the built-in rule 5404 (which represents three failed sudo attempts) within a defined time window to distinguish suspicious behavior from isolated user errors.

3.2 Rule Creation

A custom correlation rule was created in:
/var/ossec/etc/rules/local_rules.xml

The rule references built-in rule 5404 using correlation logic. It is configured with a frequency of 3 occurrences of Rule 5404 within a 120-second timeframe. Since Rule 5404 represents grouped failed sudo authentication attempts, the custom rule correlates repeated authentication failure events occurring within a short time window to identify aggressive privilege escalation behavior.

A custom Rule ID 100020 was assigned to preserve core rule integrity and maintain upgrade compatibility.

3.3 Severity & MITRE Mapping

The custom rule was configured with severity level 12 (High) to reflect the risk of repeated privilege escalation attempts.

It was mapped to:
T1548.003 – Abuse Elevation Control Mechanism: Sudo and Sudo Caching

This ensures alignment with the MITRE ATT&CK framework.

3.4 Validation & Testing

The rule was validated through controlled sudo authentication failures on the Kali Linux host. A single sudo execution did not trigger the custom rule. After multiple occurrences of Rule 5404 were generated within the 120-second window, the correlation threshold was exceeded and custom Rule ID 100020 triggered successfully with severity level 12.

Validation confirmed correct correlation logic, proper threshold enforcement, severity escalation, MITRE mapping, and successful alert indexing in the dashboard.

```
soc@wazuh-server: ~
  GNU nano 6.2                                                    /var/ossec/etc/rules/local_rules.xml
<!-- Local rules -->

<!-- Modify it at your will. -->
<!-- Copyright (C) 2015, Wazuh Inc. -->

<!-- Example -->
<group name="local,syslog,sshd,">

  <!--
  Dec 10 01:02:02 host sshd[1234]: Failed none for root from 1.1.1.1 port 1066 ssh2
  -->
  <rule id="100001" level="5">
    <if_sid>5716</if_sid>
    <srcip>1.1.1.1</srcip>
    <description>sshd: authentication failed from IP 1.1.1.1.</description>
    <group>authentication_failed,pci_dss_10.2.4,pci_dss_10.2.5,</group>
  </rule>

</group>

<group name="custom_sudo_monitoring">

  <rule id="100020" level="12" frequency="3" timeframe="120">
    <if_matched_sid>5404</if_matched_sid>
    <description>Custom High Severity Alert: Repeated occurrences of 3 failed sudo attempts within 120 seconds</description>
    <group>authentication_failures,privilege_escalation,custom_rule,</group>
    <mitre>
      <id>T1548.003</id>
    </mitre>
  </rule>

</group>
```

Figure 5– Custom Rule 100020 XML Configuration

XML configuration showing level 12, frequency (3), timeframe (120s), and correlation with rule 5404.

Custom High Severity Alert: Repeated occurrences of 3 failed sudo attempts within 120 seconds

View alerts of this Rule

Information

ID	Level	File	Path
100020	12	local_rules.xml	etc/rules

Groups
authentication_failures, privilege_escalation, custom_rule, custom_sudo_monitoring

Details

Frequency	Timeframe	If_matched_sid
3	120	5404

Compliance

Related rules

ID	Description	Groups	Compliance	Level	File
100001	sshd: authentication failed from IP 1.1.1.1.	authentication_failed, local, syslog, sshd	PCI_DSS	5	local_rules.xml

Figure 6– Custom Rule 100020 Loaded and Active in Wazuh

Dashboard view confirming frequency (3), timeframe (120s), and if_matched_sid 5404.

3.5 Advanced Correlation Strategy & Detection Depth

While the implemented detection rule successfully identifies repeated failed sudo authentication attempts, the tuning strategy behind the configuration reflects deliberate risk-based decision making rather than arbitrary threshold selection.

The correlation rule is configured to trigger when Rule 5404 (three failed sudo attempts) occurs three times within a 120-second timeframe. Since Rule 5404 represents grouped failed authentication attempts, the custom rule correlates multiple structured failure events occurring within a short timeframe to identify concentrated privilege escalation behavior. This threshold was selected to balance detection sensitivity and operational practicality.

From a detection engineering perspective, lower thresholds increase sensitivity but significantly raise false positive rates, particularly in environments where users occasionally mistype passwords. Conversely, excessively high thresholds reduce noise but introduce false negative risk, potentially allowing slow brute-force attempts to bypass detection. The selected configuration represents a calibrated midpoint designed to identify aggressive privilege escalation behavior while limiting unnecessary alert fatigue.

Alert fatigue is a critical SOC concern. Repeated authentication alerts with low contextual filtering can overwhelm analysts and reduce attention to genuinely malicious activity. By correlating multiple structured failure events rather than single login errors, the rule prioritizes behavioral patterns over isolated mistakes, improving triage efficiency.

However, it is acknowledged that a slow, distributed brute-force attempt executed over a longer time window (e.g., spaced beyond 120 seconds) may evade this specific correlation logic. This limitation reflects the trade-off between precision and coverage inherent in threshold-based detection models. In production environments, complementary anomaly-based or behavioral baselining techniques would mitigate this gap.

Additionally, the detection logic supports identification of a potential multi-stage attack chain. In a realistic intrusion scenario, an adversary may first gain SSH access using compromised credentials and subsequently attempt privilege escalation via sudo. Although this project focuses on sudo failures, the correlation structure enables future expansion toward chained detection logic combining initial access and privilege escalation patterns.

The assigned severity level (12 – High) reflects the strategic importance of privilege boundaries within Linux systems. Repeated failed attempts to access root privileges directly target administrative control, representing a high-risk security event even if authentication ultimately fails. The severity assignment therefore aligns with risk exposure rather than outcome alone.

This tuning approach demonstrates structured detection engineering methodology, emphasizing balanced threshold selection, operational SOC considerations, and forward-compatible rule design.

Phase 4 – Event Generation

4.1 True Positive Event

In this controlled test scenario, an automated script was used to generate repeated sudo authentication failures on the Linux host (kali). Each sudo execution intentionally included three consecutive incorrect password attempts, producing Rule 5404 ("Three failed attempts to run sudo") events.
When two occurrences of Rule 5404 were detected within the defined 120-second correlation window, the custom high-severity detection rule (Rule ID: 100020, Severity Level 12) was triggered.
The alert message displayed was: "Custom High Severity Alert: Repeated occurrences of 3 failed sudo attempts within 120 seconds."
Since the activity represents repeated failed privilege escalation attempts in a short timeframe, it is classified as a True Positive detection aligned with MITRE ATT&CK technique T1548.003.

Time	agent.name	rule.description	rule.level	rule.id
Feb 25, 2026 @ 19:51:50.639	kali	Three failed attempts to run sudo	10	5404
Feb 25, 2026 @ 19:51:50.639	kali	Custom High Severity Alert: Repeated occurrences of 3 failed sudo attempts within 120 seconds	12	100020
Feb 25, 2026 @ 19:51:48.683	kali	unix_chkpwd: Password check failed.	5	5557
Feb 25, 2026 @ 19:51:48.636	kali	unix_chkpwd: Password check failed.	5	5557
Feb 25, 2026 @ 19:51:46.634	kali	unix_chkpwd: Password check failed.	5	5557
Feb 25, 2026 @ 19:51:46.634	kali	unix_chkpwd: Password check failed.	5	5557
Feb 25, 2026 @ 19:51:44.645	kali	PAM: User login failed.	5	5503
Feb 25, 2026 @ 19:51:44.643	kali	unix_chkpwd: Password check failed.	5	5557
Feb 25, 2026 @ 19:51:44.640	kali	Three failed attempts to run sudo	10	5404
Feb 25, 2026 @ 19:51:44.638	kali	PAM: User login failed.	5	5503
Feb 25, 2026 @ 19:51:44.636	kali	unix_chkpwd: Password check failed.	5	5557
Feb 25, 2026 @ 19:51:44.634	kali	Custom High Severity Alert: Repeated occurrences of 3 failed sudo attempts within 120 seconds	12	100020

Figure 7– True Positive Alert Trigger

This screenshot shows Rule ID 100020 (Severity Level 12) being triggered after two occurrences of Rule 5404 ("Three failed attempts to run sudo") were detected within the defined 120-second correlation window. The alert confirms successful detection of repeated failed privilege escalation attempts on the Linux host (kali).

Time	agent.name	rule.description	rule.level	rule.id
Feb 21, 2026 @ 00:27:04.486	kali	Custom High Severity Alert: Repeated sudo authentication failures detected	12	100020

Expanded document View surrounding documents View single document

Table JSON

_index	wazuh-alerts-4.x-2026.02.20
agent.id	001
agent.ip	[redacted]
agent.name	kali
data.command	/usr/bin/su
data.dstuser	root
data.pwd	/home/kali
data.srcuser	kali
data.tty	pts/0
decoder.ftscomment	First time user executed the sudo command
decoder.name	sudo
decoder.parent	sudo
full_log	2026-02-20T16:27:02.673308-05:00 kali sudo[59763]: kali : 3 incorrect password attempts ; TTY=pts/0 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/su
id	1771622824.2234409
input.type	log
location	/var/log/auth.log
manager.name	wazuh-server
predecoder.program_name	sudo
predecoder.timestamp	2026-02-20T16:27:02.673308-05:00
rule.description	Custom High Severity Alert: Repeated sudo authentication failures detected
rule.firedtimes	16
rule.groups	custom_sudo_monitoringauthentication_failures, privilege_escalation, custom_rule
rule.id	100020
rule.level	12
rule.mail	true
rule.mitre.id	T1548.003
rule.mitre.tactic	Privilege Escalation, Defense Evasion
rule.mitre.technique	Sudo and Sudo Caching
timestamp	Feb 21, 2026 @ 00:27:04.486

Figure 8– Expanded Raw Event Details (True Positive)

The event shows repeated Rule 5404 occurrences within 120 seconds triggering Rule ID 100020 (Level 12). The log confirms three failed sudo attempts in /var/log/auth.log mapped to MITRE ATT&CK T1548.003.

4.2 False Positive Event

In this scenario, repeated sudo authentication failures were manually generated by a legitimate local administrator account during controlled testing, which caused Rule ID 100020 (Severity Level 12) to trigger after exceeding the defined correlation threshold.

Although the technical detection condition was satisfied, contextual investigation confirmed that the activity occurred within an authorized lab environment and did not represent malicious privilege escalation behavior. The alert was therefore classified as a False Positive following structured validation.

Time	agent.name	rule.description	rule.level	rule.id
Feb 21, 2026 @ 00:30:56.709	kali	PAM: Login session opened.	3	5501
Feb 21, 2026 @ 00:30:56.701	kali	PAM: Login session opened.	3	5501
Feb 21, 2026 @ 00:30:56.699	kali	Successful sudo to ROOT executed.	3	5402
Feb 21, 2026 @ 00:30:56.696	kali	PAM: Login session opened.	3	5501
Feb 21, 2026 @ 00:30:56.692	kali	PAM: Login session opened.	3	5501
Feb 21, 2026 @ 00:30:56.691	kali	Successful sudo to ROOT executed.	3	5402
Feb 21, 2026 @ 00:30:52.689	kali	Custom High Severity Alert: Repeated sudo authentication failures detected	12	100020
Feb 21, 2026 @ 00:30:52.689	kali	Custom High Severity Alert: Repeated sudo authentication failures detected	12	100020
Feb 21, 2026 @ 00:30:50.729	kali	unix_chkpwd: Password check failed.	5	5557
Feb 21, 2026 @ 00:30:50.687	kali	unix_chkpwd: Password check failed.	5	5557
Feb 21, 2026 @ 00:30:46.684	kali	unix_chkpwd: Password check failed.	5	5557
Feb 21, 2026 @ 00:30:46.684	kali	unix_chkpwd: Password check failed.	5	5557
Feb 21, 2026 @ 00:30:42.730	kali	PAM: User login failed.	5	5503
Feb 21, 2026 @ 00:30:42.730	kali	unix_chkpwd: Password check failed.	5	5557
Feb 21, 2026 @ 00:30:42.730	kali	PAM: User login failed.	5	5503
Feb 21, 2026 @ 00:30:42.680	kali	unix_chkpwd: Password check failed.	5	5557

Figure 9– False Positive Alert Trigger

This screenshot demonstrates the custom rule triggering after repeated failed sudo authentication attempts. However, review of the surrounding logs confirms that the same user ("kali") successfully authenticated shortly afterward and established a valid privileged session. No abnormal command execution, persistence activity, configuration modification, or lateral movement followed the alert. These contextual indicators confirm that the frequency threshold was met due to legitimate administrative testing rather than adversarial behavior.

4.3 Explanation & Comparison

The True Positive scenario was intentionally designed to simulate aggressive privilege escalation behavior through automated repeated sudo authentication failures. The high frequency, rapid clustering, and structured repetition of failed attempts within a short timeframe reflect behavioral characteristics commonly associated with brute-force or scripted credential abuse techniques mapped to MITRE ATT&CK T1548.003. The activity demonstrated persistence and deliberate repetition, which are typical indicators of automated attack tooling rather than human error.

From a detection engineering perspective, the True Positive case validates that the correlation logic effectively identifies concentrated privilege escalation attempts that exceed normal user behavior thresholds. The rapid event sequence, absence of successful authentication, and continued failure attempts collectively strengthen the classification as malicious simulation.

In contrast, the False Positive scenario involved legitimate administrative activity that coincidentally exceeded the defined correlation threshold. Although the same rule condition was technically satisfied, contextual analysis revealed a fundamentally different behavioral pattern. The authentication failures were temporary, followed by successful legitimate access without abnormal follow-up actions. There was no evidence of automation, privilege misuse progression, abnormal command execution, or system compromise.

The distinction between these two scenarios highlights a critical SOC operational principle: frequency-based detection identifies patterns of interest, but intent determination requires contextual validation. Alert triggers indicate risk exposure, not confirmed compromise.

Furthermore, this comparison demonstrates the importance of behavioral differentiation in modern SOC workflows. Automated adversarial activity typically exhibits consistency, persistence, and structured repetition, whereas legitimate user error tends to be irregular, limited in duration, and followed by successful correction. Recognizing these behavioral nuances enables accurate incident classification and prevents unnecessary escalation.

Ultimately, effective SOC analysis requires combining technical detection thresholds with investigative reasoning. The ability to distinguish between simulated adversarial behavior and authorized administrative activity reflects analytical maturity beyond simple rule validation.

Phase 5 – Investigation & Handling

Following the high-severity alert triggered by the custom correlation rule (Rule ID: 100020), a structured investigation was conducted to determine whether the activity represented malicious privilege escalation or legitimate administrative behavior.

The analysis focused on identifying the affected host, the user account involved, and the exact timeframe of the suspicious activity. A detailed timeline review was performed to examine the sequence of failed sudo authentication attempts and their correlation within the defined threshold window.

Additionally, contextual log analysis was carried out within the Wazuh dashboard to verify whether the activity originated from authorized testing or indicated abnormal behavior. The objective of the investigation was to assess potential security impact, confirm the nature of the event, and determine the appropriate severity classification.

5.1 Identify and Open the Triggered Alert

The investigation began by accessing the Wazuh dashboard and reviewing the list of active security alerts. The high-severity alert generated by the custom correlation rule (Rule ID: 100020) was identified based on its severity level and rule description. The alert was then opened to examine the detailed event information and related underlying logs.

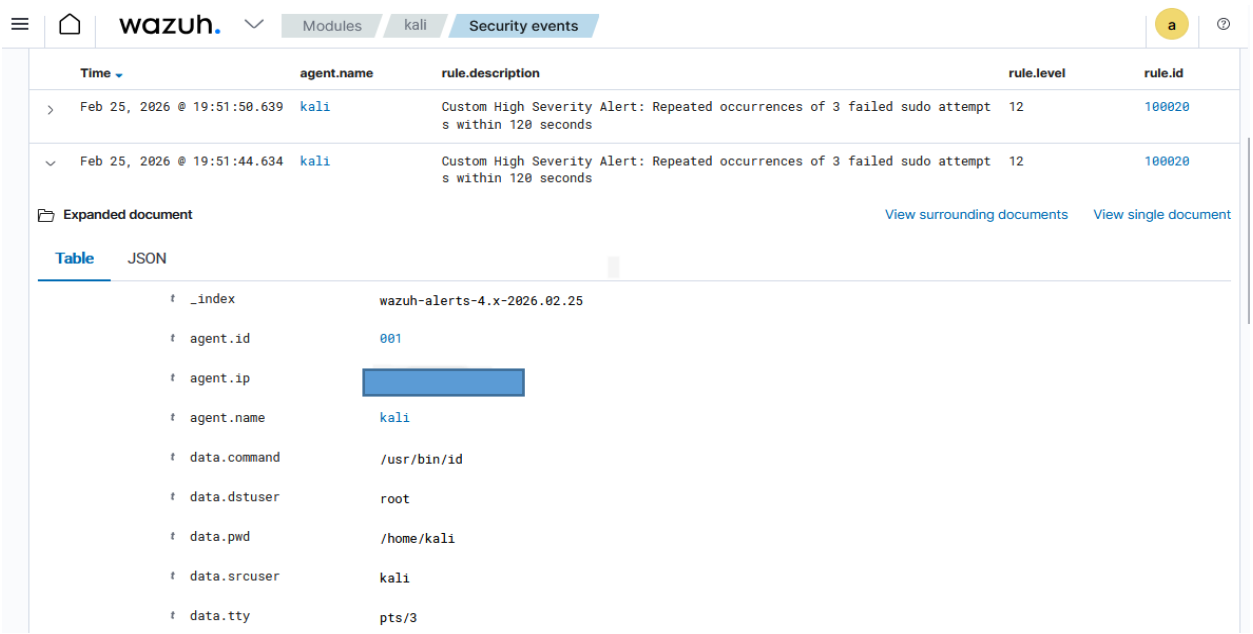

Figure 10– Identification of Triggered Alert (Rule ID 100020)

The screenshot shows the alert generated due to repeated failed sudo attempts within 120 seconds. It includes the affected host (kali), severity level (12), timestamp, and related event details used for further investigation.

5.2 Timeline Analysis of Alert Activity

After identifying the triggered alert, the timeline histogram view in the Wazuh dashboard was analyzed to evaluate the frequency and clustering of correlated events. The visualization displayed two high-severity alerts occurring within seconds of each other (19:51:44 and 19:51:50), indicating repeated sudo authentication failures within the defined 120-second window.

The timestamps confirm that the correlation threshold was met, demonstrating that the detection logic functioned correctly based on event frequency and timeframe.

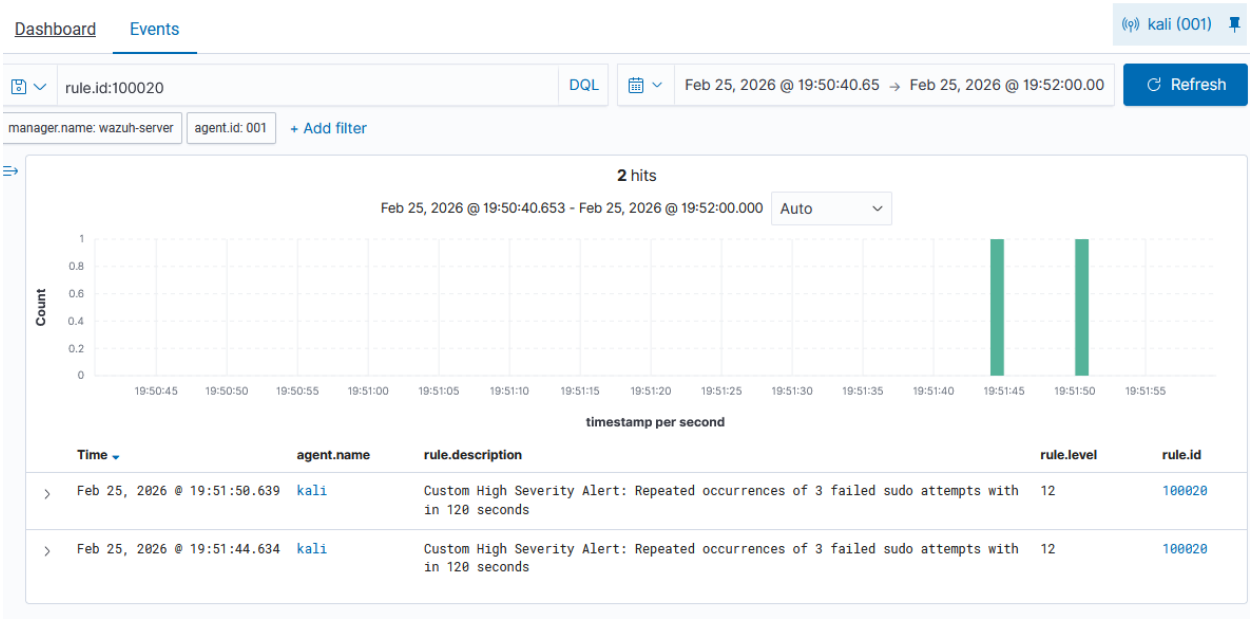

Figure 11– Filtered Timeline of True Positive Incident

The time range was narrowed to the specific incident window (19:50–19:52), isolating two correlated alerts triggered by Rule ID 100020 and confirming clustered authentication failures within a short timeframe.

5.3 Detailed Event Field Analysis

After narrowing the incident timeframe, the expanded event view was examined to analyze key log attributes associated with the triggered alert. The review focused on agent identification, source IP address, executed command, user accounts involved, log source location, rule severity, correlation frequency, and MITRE ATT&CK mapping.

The analysis confirmed that the activity originated from the monitored Linux host kali (19[redacted]). The source user “kali” attempted to execute /usr/bin/id using sudo privileges targeting the root account. Authentication logs collected from /var/log/auth.log show multiple incorrect password attempts preceding the rule trigger.

The alert was generated after meeting the configured correlation condition, resulting in a High severity (Level 12) classification aligned with MITRE ATT&CK T1548.003 under the Privilege Escalation tactic.

agent.name	[redacted]
data.command	/usr/bin/id
data.dstuser	root
data.pwd	/home/kali
data.srcuser	kali
data.tty	pts/4
decoder.ftscomment	First time user executed the sudo command
decoder.name	sudo
decoder.parent	sudo
full_log	2026-02-25T11:51:48.999489-05:00 kali sudo[663946]: kali : 3 incorrect password attempts ; TTY=pts/4 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/id
id	1772038310.730546
input.type	log
location	/var/log/auth.log
manager.name	wazuh-server

Figure 12– Event Context Fields

This view confirms the originating host (kali – [redacted]), the executed command (/usr/bin/id), the involved user accounts, and the authentication log source (/var/log/auth.log). These fields validate that the activity was a sudo privilege escalation attempt targeting the root account and provide direct contextual evidence of the authentication failure sequence.

t	predecoder.program_name	sudo
t	predecoder.timestamp	2026-02-25T11:51:48.999489-05:00
t	previous_output	2026-02-25T11:51:48.999699-05:00 kali sudo: kali : 3 incorrect password attempts ; TTY=pts/4 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/id 2026-02-25T11:51:43.314937-05:00 kali sudo[663896]: kali : 3 incorrect password attempts ; TTY=pts/3 ; PWD=/home/kali ; USER=root ; COMMAND=/usr/bin/id
t	rule.description	Custom High Severity Alert: Repeated occurrences of 3 failed sudo attempts within 120 seconds
#	rule.firedtimes	2
#	rule.frequency	3
t	rule.groups	custom_sudo_monitoringauthentication_failures, privilege_escalation, custom_rule
t	rule.id	100020
#	rule.level	12
◐	rule.mail	true
t	rule.mitre.id	T1548.003
t	rule.mitre.tactic	Privilege Escalation, Defense Evasion
t	rule.mitre.technique	Sudo and Sudo Caching
🗓	timestamp	Feb 25, 2026 @ 19:51:50.639

Figure 13– Rule & Detection Metadata

This section verifies the detection logic attributes, including Rule ID 100020, severity level 12, correlation frequency, and MITRE ATT&CK mapping (T1548.003). The metadata confirms that the alert was generated due to repeated failed sudo authentication attempts within the configured timeframe, demonstrating correct rule correlation and classification under the Privilege Escalation tactic.

5.4 Contextual Log Correlation and Behavior Validation

To validate the nature of the activity, the "View surrounding documents" feature was used to review authentication logs occurring immediately before and after the triggered high-severity alert.

The correlated events included multiple unix_chkpwd: password check failed and PAM: authentication failure entries associated with the same user account (kali). These authentication failures were linked to repeated attempts to execute the privileged command **/usr/bin/id** targeting the root account.

The lower-level authentication events (Rule 5503 and Rule 5557) preceded Rule 5404 ("Three failed sudo attempts"), which ultimately triggered the custom correlation rule (Rule ID 100020). This sequential event chain demonstrates layered authentication failure progression culminating in the correlation trigger, reinforcing that the alert was generated due to structured repeated escalation attempts rather than an isolated user error.

Figure 14– Correlated Authentication Failure Events.

This view illustrates multiple lower-level authentication failure events (unix_chkpwd and PAM) preceding the high-severity correlation alert. The temporal clustering of these events confirms that the detection was triggered through progressive authentication failures rather than a single isolated attempt.

5.5 Impact Assessment and Severity Determination

Following log correlation and behavioral validation, the investigation confirmed that the activity originated from the local host **kali** and involved repeated failed sudo authentication attempts targeting the **root** account. No evidence of external access, malware activity, or lateral movement was identified during analysis.

Although the custom rule was configured with a **High severity level (12)** due to repeated privilege escalation attempts within a short timeframe, contextual investigation confirmed that the activity occurred within a controlled lab environment and did not result in successful root access.

Therefore, the incident impact was assessed as low within the controlled lab environment, while the detection pattern itself represents **high-risk behavior in a production environment** due to its association with privilege escalation attempts.

5.6 Extended Analytical Pivots

Beyond immediate alert validation, additional investigative pivots were performed to assess potential broader compromise scenarios and verify environmental integrity.

Cross-host correlation was reviewed to determine whether similar sudo authentication failures occurred on other monitored endpoints. No related authentication anomalies were identified, confirming that the activity was isolated to the kali host.

SSH authentication history was also examined to identify any suspicious remote access attempts preceding the sudo failures. No abnormal SSH login patterns, brute-force attempts, or external source IP anomalies were observed within the surrounding timeframe.

Privileged session auditing was conducted to verify whether any successful root sessions were established following the authentication failures. Log analysis confirmed that no unauthorized root session was created and that no privileged command activity occurred beyond the intended lab simulation.

Additional checks were performed for potential lateral movement indicators, including abnormal user switching (su), account creation events, remote execution activity, or credential reuse patterns. No evidence of propagation behavior or secondary compromise activity was identified.

Two threat hypotheses were considered during the investigation: an external adversary scenario involving prior SSH compromise followed by privilege escalation, and an insider misuse scenario involving legitimate access with abnormal privilege behavior. Neither scenario was supported by log evidence.

No additional indicators of compromise (IOC), including abnormal process execution, persistence mechanisms, unauthorized privileged sessions, or outbound network anomalies, were identified during the extended investigation window. These findings confirm that the alert resulted from controlled testing rather than an active intrusion.

Phase 6 – Escalation Ticket

A formal SOC escalation ticket was generated for this incident. The complete operational ticket is provided as a separate attachment

The complete escalation ticket is available at the following secure link:

“link.pdf”.

6.1 Incident Summary

On February 25, 2026, the SIEM detected repeated failed sudo authentication attempts on the Linux host “kali” ([redacted]). A scripted activity generated multiple incorrect password attempts within a 120-second window while attempting to execute /usr/bin/id with root privileges. The custom detection rule (ID 100020, Level 12) was triggered after the predefined threshold of repeated failures was exceeded.

Although no successful privilege escalation occurred, the activity demonstrates automated behavior consistent with credential brute-force or privilege escalation attempts. If successful, such access could grant full administrative control over the system, potentially impacting sensitive data, system integrity, and operational availability. The event was escalated to ensure proactive risk management and validation of system security posture.

6.2 Detection Source

The alert was generated by the Wazuh SIEM platform using a custom correlation rule (ID: 100020, Level 12) configured in local_rules.xml. The rule is designed to trigger when multiple occurrences of Rule 5404 are detected within a 120-second timeframe.

The detection was based on authentication failure events collected from /var/log/auth.log on the Linux agent “kali” ([redacted]). The rule identifies repeated privilege escalation attempts and correlates multiple failed events into a single high-severity alert.

6.3 Timeline of Events

19:51:38.427 – Initial failed sudo authentication attempts recorded in /var/log/auth.log for user “kali” while attempting to execute /usr/bin/id as root.

19:51:40.637 – 19:51:44.645 – Rapid consecutive authentication failures detected, including multiple unix_chkpwd and PAM failure events.

19:51:44.634 – Custom correlation rule (ID 100020, Level 12) triggered after multiple correlated sudo authentication failure events occurred within the configured 120-second timeframe.

19:51:50.639 – Additional correlated high-severity alert generated as repeated failures continued within the defined threshold window.

6.4 Impact Assessment

The authentication attempts were unsuccessful, and no root access was obtained. There is no evidence of system compromise, lateral movement, or successful privilege escalation. The activity was limited to repeated failed sudo authentication attempts by the local user "kali" within a controlled lab environment.

If such attempts were successful in a production environment, unauthorized root access could allow modification of critical system files, installation of malicious software, data exfiltration, creation of persistence mechanisms, or disruption of essential services. This could directly impact system integrity, data confidentiality, and service availability.

The rapid and repeated nature of the authentication failures increases organizational risk because it may indicate automated or brute-force behavior rather than accidental user error. Repeated high-frequency attempts elevate the likelihood of credential compromise and require proactive investigation to prevent potential escalation into a successful system breach.

6.5 Evidence

Log Evidence:

Authentication logs collected from */var/log/auth.log* confirm repeated failed sudo attempts by user "kali" while executing */usr/bin/id* with root privileges. The log entries indicate multiple incorrect password attempts within a short timeframe, confirming that authentication was unsuccessful and no privilege escalation occurred.

Rule Trigger Evidence:

The Wazuh SIEM generated a high-severity alert titled **"Custom High Severity Alert: Repeated occurrences of 3 failed sudo attempts within 120 seconds"** (Rule ID: 100020, Level 12). The alert was triggered after the configured threshold of three failed sudo authentication attempts occurred within a 120-second window, demonstrating rule-based correlation of rapid authentication failures.

Screenshot References:

- **Figure 7** and **Figure 8** – True Positive alert trigger and expanded raw event details.
- **Figure 10** – Identification of triggered alert within the dashboard.
- **Figure 11** – Filtered timeline of the incident window.
- **Figure 12** – Event Context Fields.
- **Figure 13** – Rule & Detection Metadata.
- **Figure 14** – Correlated Authentication Failure Events.

6.6 Severity Justification

The alert was assigned **Severity Level 12 (High)** because it involves repeated failed attempts to obtain elevated (root) privileges within a short timeframe. Privilege escalation attempts directly target administrative control of a system, which represents a critical security boundary.

The rule is configured to trigger when three failed sudo authentication attempts occur within 120 seconds, indicating rapid and potentially automated behavior rather than isolated user error. Threshold-based correlation increases severity because it demonstrates persistence and intent, which are characteristics commonly associated with brute-force or credential-based attacks.

Although the attempts in this case were unsuccessful and occurred in a controlled lab environment, similar activity in a production system could significantly increase the risk of unauthorized access. Escalation is therefore appropriate to ensure proactive investigation, validation of account behavior, and confirmation that no additional malicious activity occurred.

6.7 Recommendation / Next Steps

It is recommended that Tier 2 analysts or the Incident Response team validate the legitimacy of the repeated sudo activity performed by user “kali” on the affected host. The account should be reviewed to confirm whether the rapid authentication attempts were authorized administrative actions or indicative of abnormal behavior.

A broader log review is recommended to verify that no successful privilege escalation occurred outside the identified timeframe and that no additional suspicious commands or anomalous activities were executed.

If deemed necessary, the user’s password should be reset and account permissions reassessed to ensure adherence to the principle of least privilege. Continuous monitoring should be maintained to detect further high-frequency authentication attempts or privilege escalation behavior.

These actions help reduce the risk of credential compromise, strengthen access control governance, and ensure early detection of potential escalation attempts within the environment.

Phase 7 – Rule Tuning & Improvement

7.1 Reducing False Positives

The current rule configuration triggers an alert when repeated sudo authentication failure events occur within a **120-second window**. While this threshold is effective in detecting repeated authentication failures during testing, it may generate false positives in production environments where users occasionally mistype passwords.

Threshold Adjustment

To reduce unnecessary alert noise, the detection threshold can be increased from three failed attempts to five failed attempts. This adjustment decreases alerts caused by common user errors while still identifying abnormal behavior patterns indicative of potential privilege escalation attempts.

Time Window Adjustment

The aggregation window can be further extended beyond the current 120-second configuration if operational requirements demand reduced alert sensitivity. For example, increasing the timeframe would require authentication failures to occur within a broader time window before triggering correlation. Adjusting the time window allows tuning between detection responsiveness and noise reduction, depending on organizational risk tolerance.

Host Exclusion Strategy

In production environments, known lab, testing, or administrative maintenance systems may generate frequent authentication failures during legitimate activities. Such systems can be excluded from the production rule scope to reduce unnecessary alerting.

However, exclusion rules must be carefully documented, approved, and regularly reviewed to prevent security blind spots or misuse that could allow adversaries to bypass detection controls.

7.2 Production-Level Enhancements

Correlation with SSH Authentication Events

The detection logic can be enhanced by correlating repeated sudo authentication failures with SSH login activity on the same host. If multiple SSH authentication failures are followed by repeated sudo failures within a short time window, the alert severity should increase. This correlation enables detection of a realistic attack chain involving initial access followed by privilege escalation attempts.

Tiered Alert Escalation Logic

A dynamic severity model can be implemented based on event volume and correlation context:

- Five failed sudo attempts → Medium severity
- Ten or more failed sudo attempts → High severity
- Combined SSH brute-force activity followed by sudo failures → Critical severity

This structured escalation model improves prioritization, supports analyst triage workflows, and reduces alert fatigue by aligning severity with risk level.

User Behavior Baseline Monitoring

Where feasible, detection logic should incorporate behavioral baselining. Alerts should trigger when sudo authentication failures exceed a user's normal operational pattern or occur during unusual hours. Monitoring deviations from established user behavior improves detection precision and supports anomaly-based threat identification strategies.